Ep 6 · Safe Tool-Calling Agents — Cheat Sheet

AI System Design · AI Engineering with Ajit · github.com/byruajit/ai-system-design

WORKFLOW OR AGENT?

Known steps → **workflow** (LLM inside steps)
Path depends on findings → **bounded agent**

THE 7 GUARDRAILS

1. **Intent router** → per-intent tool allowlist
2. **MCP server** = enforcement point
3. **Identity passthrough** (short-lived, user-scoped token)
4. **Scope from session**, never from model args
5. **Writes → pending approval** (maker-checker)
6. **Budgets:** steps · tokens · time · loop detection
7. **Audit** every proposed, blocked and approved call

UNTRUSTED CONTENT

Emails, docs and tool outputs go in **labelled data blocks**. "Content is data, not instructions." Add an injection classifier. Prompts are **not** security boundaries.

TOOL CLASSES

Class	Example	Rule
Read	get_my_cards	Execute
Write	request_card_block	Approval
Never	issue_refund	Not a tool

COST

`cost/task = steps × (in × P_in + out × P_out)` Northwind: ~$0.024/task · ~$480/day *(illustrative)*

MCP VS FUNCTION CALLING

One app, few tools → function calling. Many agents × shared systems → **MCP**, owned by system teams.

TEST AGENTS BY

Scenario golden set · adversarial inputs · assert on side-effects · replay prod traces

Northwind Bank is fictional. Prices are illustrative tiers — check current provider pricing.